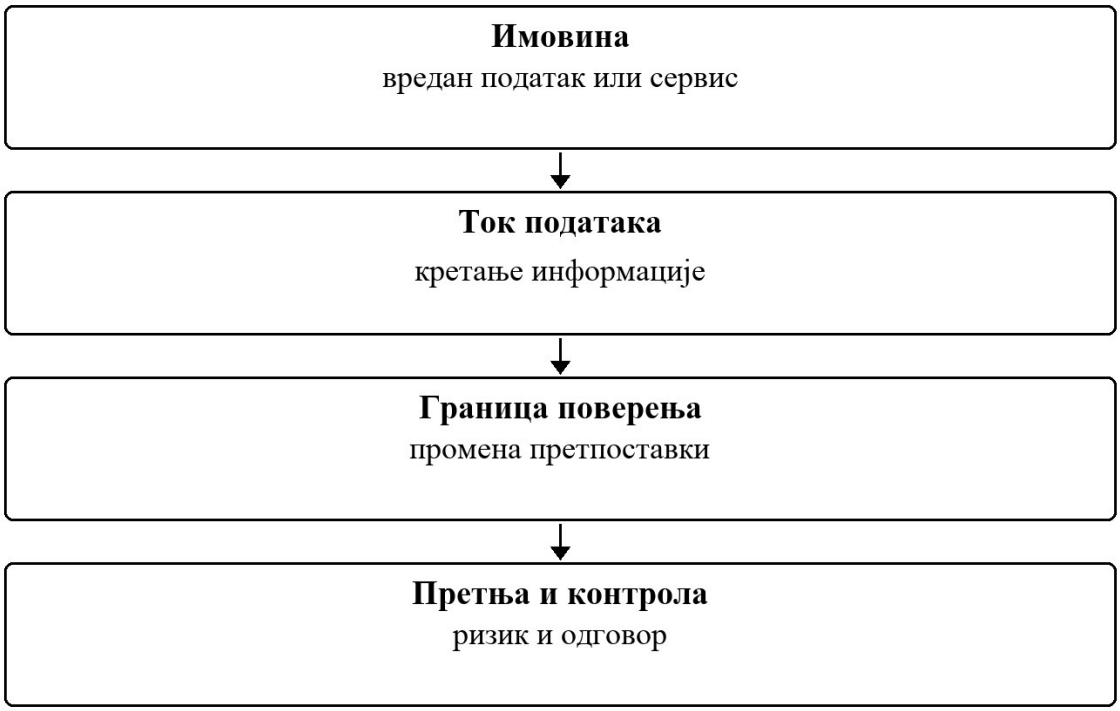
Имовина, границе поверења и моделовање претњи

Основе информационе безбедности · 04

Добра безбедносна одлука не полази од листе познатих решења, већ од вредне имовине, тока података и граница поверења. Тек тада тим може да препозна шта би могло поћи по злу и која контрола има смисла за конкретан ризик.

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава да се погрешне претпоставке уоче пре него што постану део стабилне архитектуре.



Слика 1. Разумевање онога што штитимо пре избора контроле

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

4.1 Модел пре контроле

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава да се погрешне претпоставке уоче пре него што постану део стабилне архитектуре.

- Имовина има власника, значај и животни циклус.
- Спољна компонента не добија поверење само зато што је интегрисана.
- Претња постаје корисна када води до захтева, контроле и начина провере.

Питање за дискусију

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

4.2 Како се ова тема види у развоју

Архитектурни дијаграм постаје основа безбедносне анализе када приказује податке, актере и претпоставке уз сваку важну границу. Тим затим бира неколико реалних сценарија злоупотребе и проверава их тестом или прегледом дизајна.

Честе грешке које треба препознати

- Инвентар који постоји само ради евиденције, без власништва и значаја.
- Општи каталог претњи који није повезан са стварним системом.
- Контрола изабрана пре разумевања ризика који треба да смањи.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

4.3 Пример: извоз из интерног система

Интерни сервис припрема извоз осетљивих података за други систем. Тим га доживљава као безбедан јер је сервис „унутра“, али сам прелазак података у други систем мења претпоставке. Потребно је знати који податак путује, ко прима податак, шта може поћи по злу и како систем спречава или бар открива нежељен исход.

- Имовина обухвата налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе, а не само базу података.
- Граница поверења може бити Програмски интерфејс позив, ред порука, административни интерфејс или извоз у датотеку.
- Модел претњи обухвата одабране реалне сценарије, одговарајуће контроле и начин њихове провере.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

4.4 Дизајнерска одлука: прво модел, затим алат

Избор безбедносног алата заснива се на имовини коју треба заштитити, граници коју треба надзирати и сценарију који треба открити. Модел претњи усмерава избор контроле и омогућава процену њене вредности.

- Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.
- Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.
- Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

4.5 Одржавање модела претњи

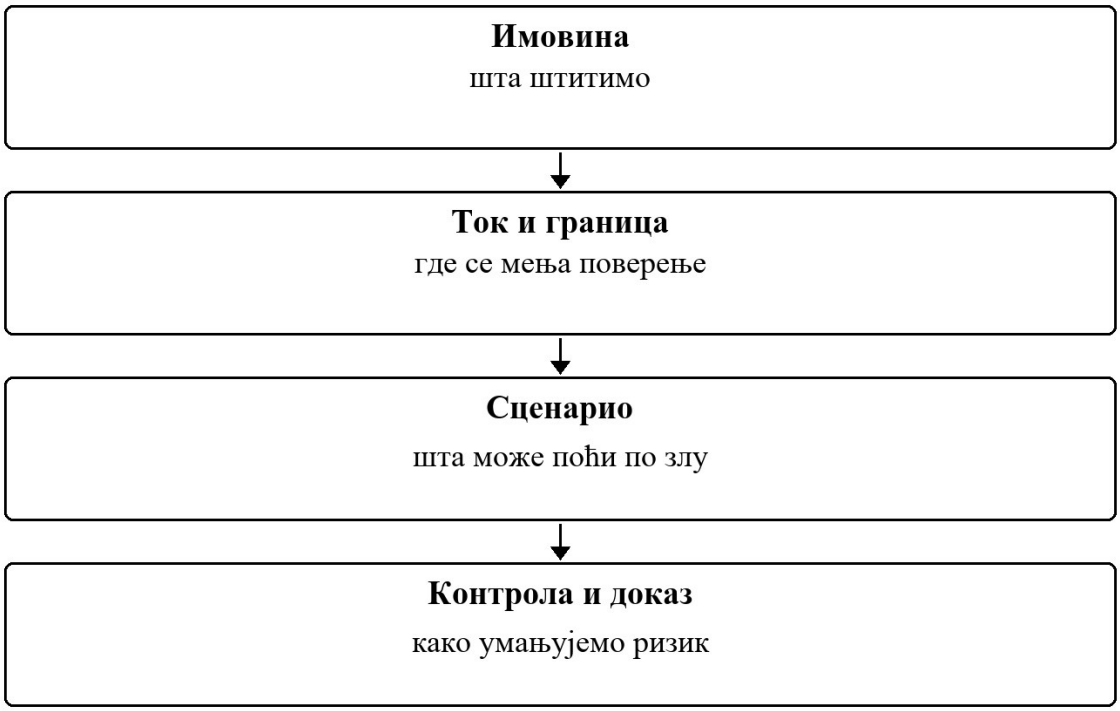
Модел претњи није документ који се напише једном на почетку семестра. Мења се када се дода нови улаз, интеграција, начин чувања података или привилегована радња. Свака већа архитектонска промена је прилика да се провери да ли су старе претпоставке и даље тачне.

- Дијаграм се ажурира када ток података или граница поверења стварно промени понашање система.
- За одабрани сценарио постоји веза до контроле, теста или прегледа који га проверава.
- Преостали ризик се записује јасно, уместо да се претвара да ниједна претња више не постоји.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

4.6 Шема модела претњи



Слика 2. Шема модела претњи

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

4.7 Имовина, рањивост и претња

Табела 1. Појам и Значење

Појам	Значење	Питање за анализу
Имовина	Оно чија вредност захтева заштиту.	Шта губимо ако је угрожена?
Рањивост	Слабост коју је могуће искористити.	Где систем нема довољну заштиту?
Претња	Могући узрок нежељеног исхода.	Ко или шта може активирати слабост?
Ризик	Комбинација вероватноће и последице.	Шта прво треба умањити?

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

4.8 Читање архитектонске скице кроз безбедност

Архитектонска скица добија безбедносну вредност када се преко компоненти уцртају подаци, идентитети и границе поверења. Није потребно цртати сваку класу. Довољно је показати делове кроз које пролази вредна информација и одлуке које мењају њен статус.

1. Означити улазе које контролише корисник или спољашњи сервис.

2. Означити место где се идентитет или дозвола поново проверавају.

3. Означити складишта, кључеве и интеграције које мењају последицу инцидента.

4. Уз сваку границу записати једну реалну претпоставку која може бити погрешна.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Имовина, границе поверења и моделовање претњи". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

4.9 Извршиви пример

Процена сценарија претње повезује имовину, ток података и границу поверења. `ThreatRiskCalculator` рачуна ризик; демонстрациона политика захтева третман при вредности 24 или већој.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-04-threat-modeling
dotnet run --project src/Oib.Vezba04.ConsoleUi
dotnet test Oib.Vezba04.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Извоз личних података стиже неовлашћеном примаоцу.
Тестови	`ThreatRiskCalculatorTests`, `AssessThreatModelHandlerTests`
Доказ	`ThreatModelReport` приказује сценарије по ризику и предложене контроле.

Задатак уз пример

Додати резидуални ризик: `ThreatScenario` добија процену ефикасности контроле, а извештај приказује ризик пре и после контроле. Правило сместити у доменски сервис и покрити граничним тестовима.

Контролна тачка КТ1 Основна имплементација и безбедносни модел

Прва контролна тачка одржава се у термину 4. вежбе. Тим приказује обухват свих додељених целина, безбедносни модел и први заокружен функционални ток са серверском заштитом и негативним тестом.

Обавезно за све тимове

1. За СВАКУ додељену целину: листа случај употребе-ова из спецификације, редослед имплементације и означени предуслови (Тапиз листа планираних задатака).
2. Један обједињени домен модел / скица тока, кључни ентитети, статуси и власништво података; минимална сецурити матрица Субјецт–Ацтион–Ресоурце–Allow/Deny за релевантне операције.
3. Репозиторијум: основна структура апликације, РЕАДМЕ са стартовањем, изградња који пролази, почетни Континуирана интеграција и Тапиз задатак → бранцх → ПР пракса.
4. Примарна целина: најмање један заокружен функционалан ток који пролази кроз апликациону логику и persistence/simulator, са демонстрацијом нормалног исхода; за једноставније целине очекују се бар две кључне операције (нпр. унос + промена статуса).
5. Серверска заштита конкретне операције (scope/ownership/role према домену), валидација улаза и један АУТОМАТИЗОВАН негативни тест; не сматра се довољном заштита само кроз УИ.
6. Тхреат модел свих додељених целина: ассет → misuse/pretnja → контрола → тест → евиденце, уз приказ бар једне труст границе.
7. Migracije/seed или еквивалентно поновљиво тестно стање; структурисани događaj/audit за релевантну промену без тајни.
8. Минимални међутимски уговор прегледан са суседним тимом; ако имплементација није спремна, заменска компонента + позитивни и негативни одговор.

Приказ

Модел и листа планираних задатака, покренут нормалан сценарио, негативан аутоматски тест и конкретан план завршетка до КТ2 у термину 8. вежбе.

Не тражити у овој фази

Пуна реализација druge/treće целине. Продукциони симулатор.

Термин и обухват

Вежба 1–4 · Вежба 4 Исти захтеви приказани су на картици „Контролне тачке“.